INFORME TÉCNICO DE RESOLUCIÓN CTF

La FLAG perdida

Burp Suite · Análisis de un inicio de sesión

Integrante: Felipe Segura

Asignatura: Ciberseguridad Avanzada

Docente: Rodrigo Ledezma

Fecha: 3 de noviembre de 2026

Resultado documentado

La captura disponible muestra acceso concedido y la FLAG del laboratorio.

Elaborado a partir de la resolución y las evidencias disponibles del desafío.

2. Introducción

El reto presenta un portal de archivo digital con un formulario de administrador. La misión es examinar el inicio de sesión con Burp Suite y recuperar la FLAG oculta en la aplicación de laboratorio.

3. Análisis inicial

Se contó con la URL del reto, instrucciones para interceptar una petición POST y pistas sobre el campo username. La hipótesis, sugerida por el enunciado, fue que el formulario podía ser vulnerable a inyección SQL.

4. Herramientas utilizadas

Burp Suite Community Edition: Proxy permitió observar la petición del formulario; Repeater permitió modificarla y reenviarla. Se eligió para controlar los parámetros y comparar la respuesta.

Navegador integrado: permitió acceder al escenario y generar la petición de autenticación.

5. Metodología de resolución

Paso 1. Identificación de la petición

Se siguieron las pistas de los compañeros: abrir el navegador desde Proxy, visitar el portal del desafío, activar Intercept e ingresar datos de prueba. Se identificó la petición POST del formulario y se revisaron sus parámetros en Pretty.

Paso 2. Modificación y reenvío

La captura conserva la prueba en Repeater. Se modificó username con una condición SQL verdadera y un comentario, manteniendo password=admin123. El cuerpo observado es:

```
POST /index.php HTTP/1.1
Host: desafiouls.free.nf
Content-Type: application/x-www-form-urlencoded

username=%27+or+1%3D1--+-&password=admin123
```

La parte del usuario decodifica a ' or 1=1-- -. La condición 1=1 es verdadera y -- inicia un comentario SQL en los dialectos compatibles. El acceso concedido es consistente con una omisión de autenticación por inyección; la captura no permite reconstruir la consulta del servidor.

Paso 3. Lectura de la respuesta

Se reenvió la petición y se revisó Response > Render. La página respondió «Acceso Concedido» y mostró una FLAG. No fue necesario documentar acceso a otros registros para obtenerla.

6. Evidencias

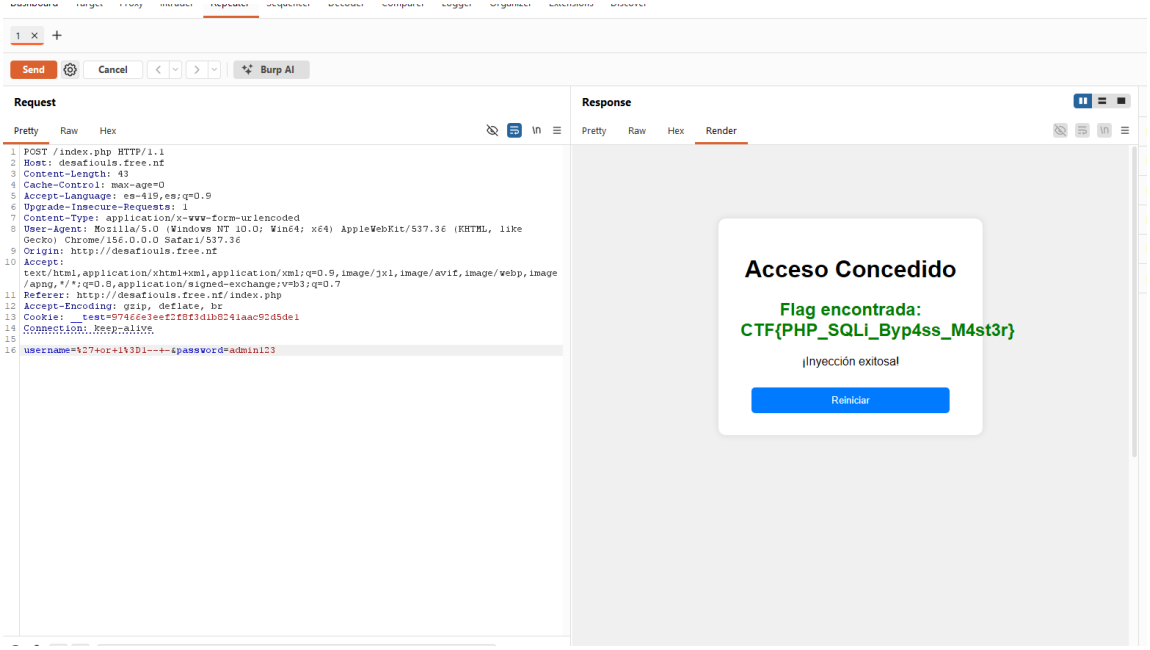


Figura 1. Evidencia original en Repeater: parámetro username modificado y respuesta con la FLAG.

7. Uso de pistas

Se utilizaron las tres pistas del enunciado: activar Intercept, revisar la petición en Pretty y probar una condición como OR 1=1. Ayudaron a identificar el POST y el parámetro que debía modificarse. La resolución reconoce apoyo de inteligencia artificial para comprender el uso de Burp Suite.

8. Obtención de la FLAG o resultado

La FLAG se encontró en la respuesta renderizada de la petición modificada. Su contenido se puede leer directamente en la captura:

```
CTF{PHP_SQLi_Byp4ss_M4st3r}
```

9. Análisis del proceso

La dificultad fue aprender a interceptar y editar la petición. Las pistas orientaron la prueba y Repeater permitió comparar la respuesta. La evidencia demuestra una autenticación vulnerable; el alcance de la prueba se limita a ese formulario.

10. Análisis ético

La prueba corresponde al portal entregado para la actividad. Alterar solicitudes de autenticación debe limitarse al alcance autorizado. Como medida defensiva, las consultas parametrizadas evitan que los datos del usuario se interpreten como instrucciones SQL.

11. Conclusiones

Burp Suite permitió modificar el inicio de sesión y observar la FLAG en la respuesta. El reto mostró la importancia de validar la autenticación y utilizar consultas parametrizadas para evitar inyecciones SQL.

Fuentes y archivos de respaldo

Pauta_Resolucion_Desafio_CTF.docx: estructura del informe.

Desafío - Burp/Resolucion.md y Desafío Burp Suite.docx.pdf: resolución y pistas.

Captura de pantalla 2026-11-02 162203-1.png: solicitud modificada y FLAG.